Windows Domain

1. Problem: Small vs Large Network

Small network

- Example: 5 computers, 5 employees
- Manual management works: create users, configure accounts, fix computers on-site

Large network

- Example: 157 computers, 320 users, 4 offices
- Problems:
- Too many users to manage manually
- Policies must be repeated on every computer
- On-site support for all users is inefficient
- → Need a solution for central management

2. Solution: Windows Domain

- A Windows Domain groups computers and users for centralized administration
- Solves the problem of manual management in large networks

3. Component:

Active Directory (AD)

- Active Directory stores:
- User accounts & passwords
- Computer accounts
- Permissions & security policies
- Allows centralized identity and policy management
- → Solves the problem of having to configure each computer/user separately

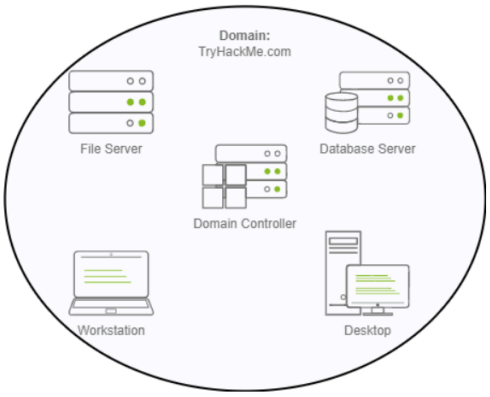
Domain Controller (DC)

A Domain Controller is a server running Active Directory

Responsibilities:

- Verify user credentials (authentication)
- Apply policies across the network
- → Solves the problem of decentralized control and inconsistent security policies

4. Advantages of Windows Domain



Centralized Identity Management

- Create a user once → usable on any computer
- Solves repeated account creation on each PC

Centralized Security Policies

- Admin can restrict access, apply permissions, deploy policies across all computers
- Solves inconsistent or difficult-to-manage security

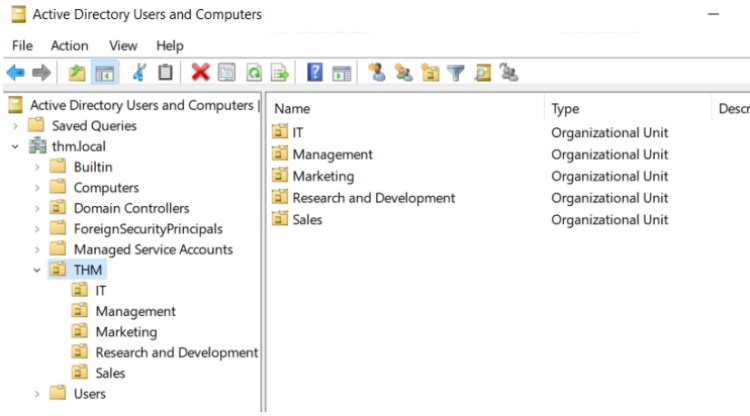
5. Real-World Example

School/university networks:

- One username/password works on any campus computer
- Authentication is done by Active Directory
- Shows how centralized management works in real life

Active Directory Domain Services (AD DS)

Core of Windows Domain → AD DS



Problem

In a large organization:

- Many users
- Many computers
- Many resources (files, printers, services)

Managing everything separately is difficult.

Solution

- Active Directory Domain Services (AD DS)
- AD DS acts as a central catalogue that stores all network objects.

Objects in Active Directory

AD DS manages everything as objects.

Examples:

- Users
- Machines (computers)
- Groups
- Printers
- Shared resources

All management inside a domain happens through these objects.

1. Users Object

Represents entities that need access to network resources.
Users are Security Principals.

Security Principal Meaning an object that:

- Can be authenticated
- Can receive permissions
- Can access resources

Types of Users

1. People Users
    - Represent employees
    - Used for login and daily work

2. Service Users
    - Used by services like IIS or MSSQL
    - Have limited permissions
    - Only run specific services

Instead of giving permissions individually on each computer:
→ Users are authenticated centrally through AD.

2. Machine (Computer) Objects

Every computer joining the domain becomes a machine object.

- Machines are also security principals
- Each machine gets an account
- Account name format:
    - ComputerName$
    - Example: DC01$
- Password automatically changes
- Very long random password (~120 characters)

3. Security Groups

- Contains users or machines
- Assigns permissions collectively
- When a user joins a group:
    - → They automatically inherit group permissions.

Groups can contain:

- Users
- Machines
- Other groups

A user can belong to multiple groups.

Management Tool (Active Directory Users and Computers)

Tool used to manage:

- Users
- Computers
- Groups
- Organizational Units

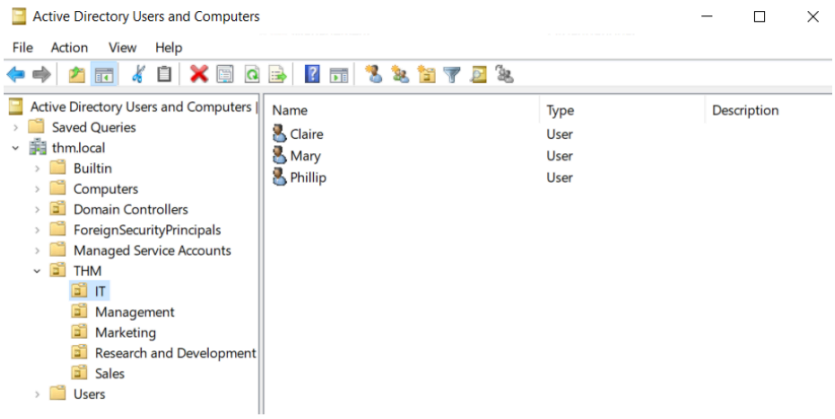
Runs on the Domain Controller.

Organizational Units (OUs)

Container objects used to organize users and computers.

Apply Group Policies based on:

- Department
- Role
- Function



Example:

```
Company
├── IT
├── Sales
├── Marketing
└── Management
```

A user/computer belongs to only one OU

Active Directory – OU Management and Delegation

Open Active Directory Users and Computers (ADUC) and review the existing Organizational Units (OUs). Compare the current Active Directory structure with the provided organisational chart. Identify any extra OUs, missing users, or users placed in incorrect departments.

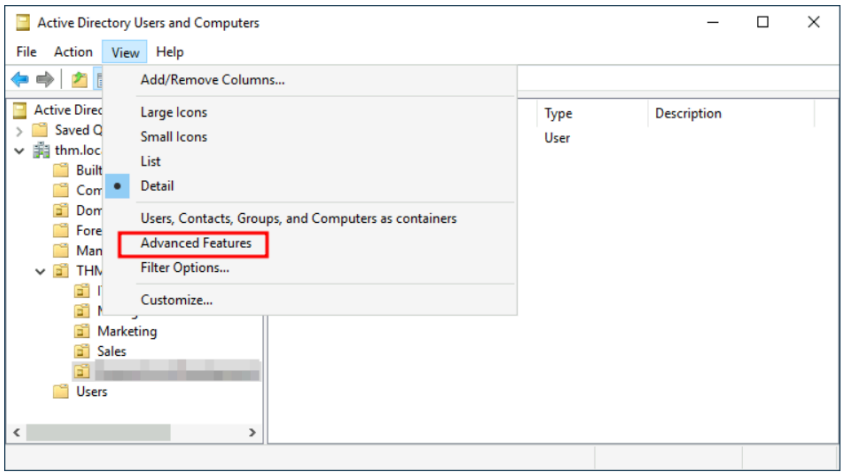
Deleting Extra Organizational Units (OU)

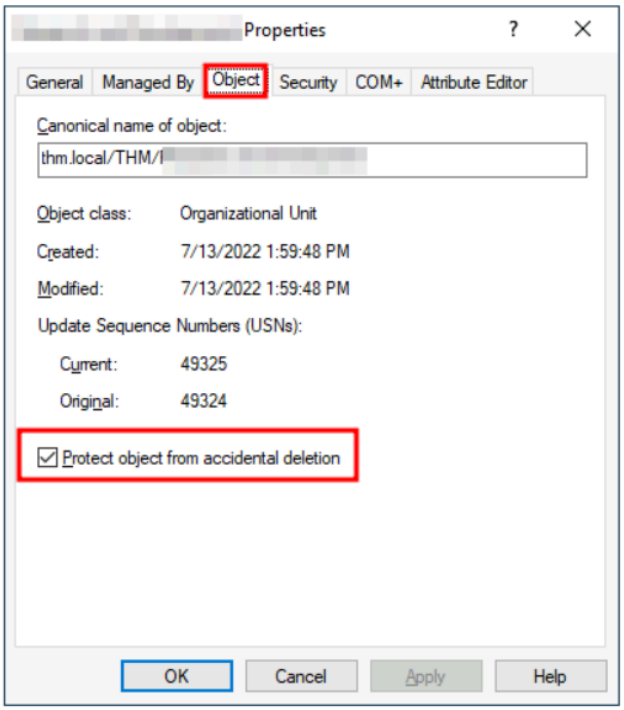
Sometimes an OU cannot be deleted because it is protected against accidental deletion.

Steps to delete a protected OU:

- Open Active Directory Users and Computers.
- Click View from the top menu.
- Enable Advanced Features.
- Right-click the target OU and select Properties.
- Go to the Object tab.
- Uncheck Protect object from accidental deletion.
- Click Apply and OK.
- Right-click the OU again and select Delete.
- Confirm deletion.

Note: Deleting an OU will also delete all users, groups, and sub-OUs inside it.



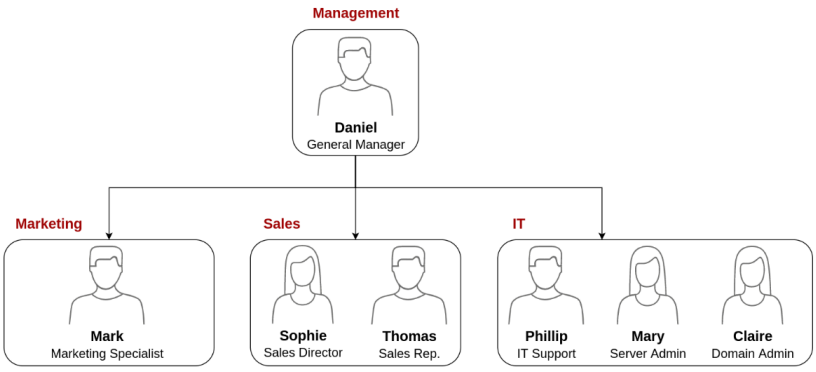


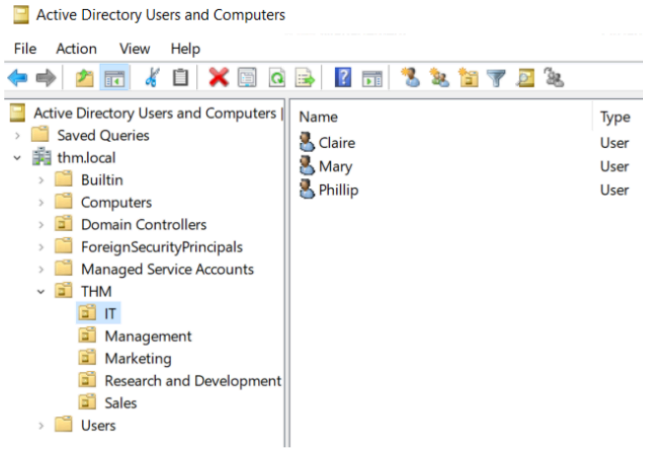
Delegation of Control in Active Directory

Delegation allows specific users to perform administrative tasks without granting full Domain Administrator privileges.

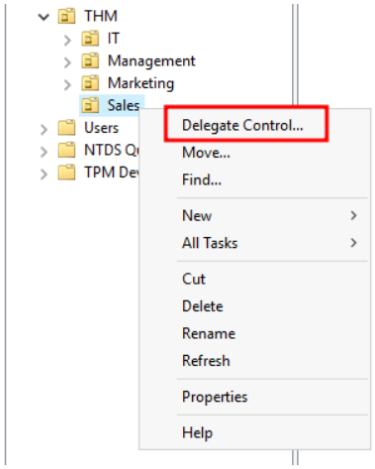
A common example is allowing IT support staff to reset passwords for department users.

According to the organisational chart, Phillip is responsible for IT support.





Delegating Password Reset Permission

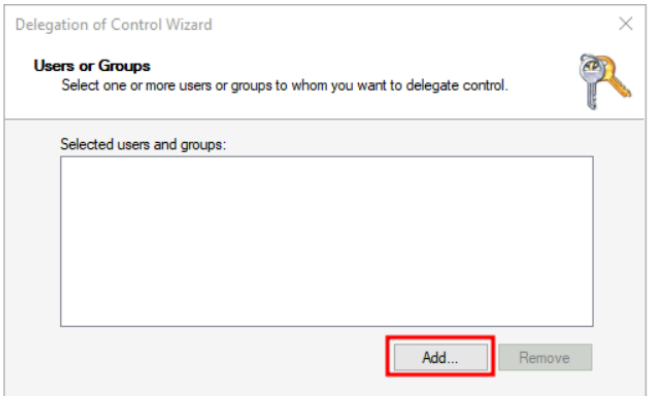


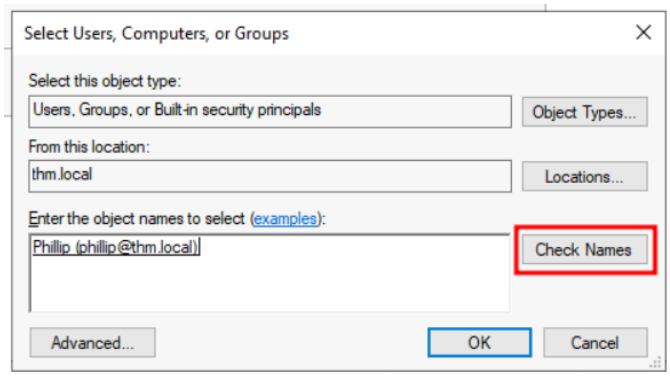
Example: Delegate password reset permission for the Sales OU to Phillip.

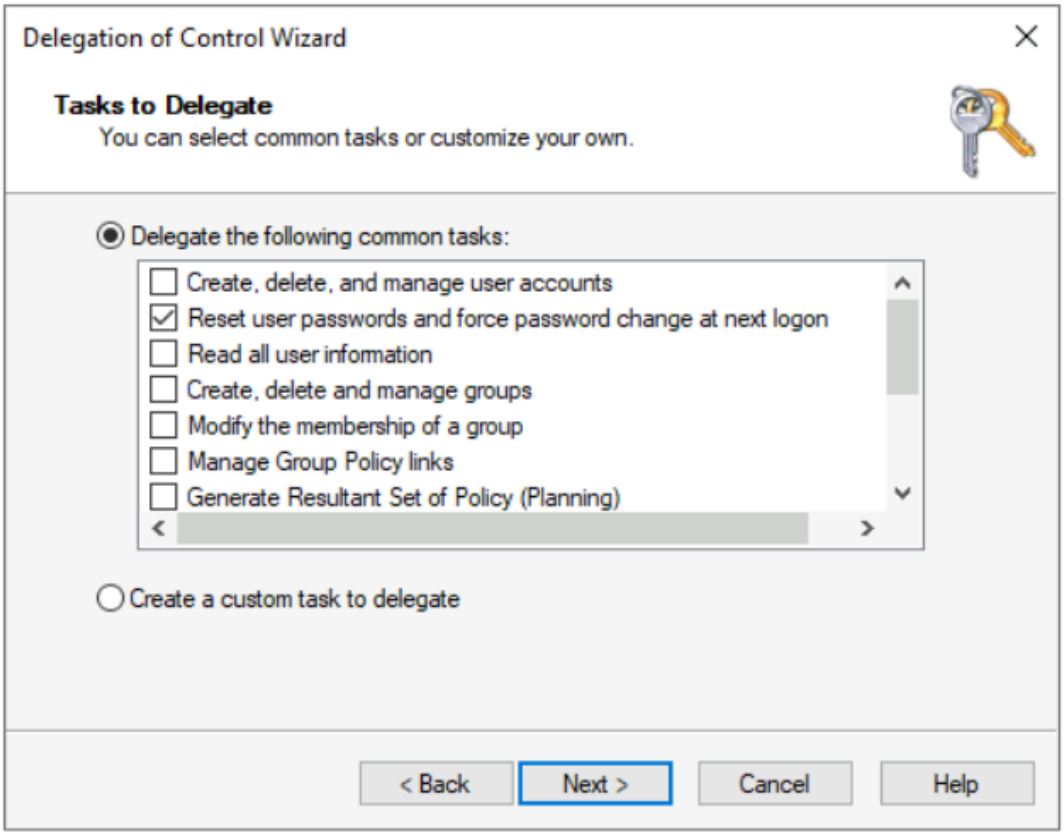
Steps:

1. Right-click the Sales OU.
2. Select Delegate Control.
3. Click Next.
4. Add the user by typing phillip.
5. Click Check Names to verify the account.
6. Click Next.
7. Select Reset user passwords and force password change at next logon.
8. Complete the wizard.

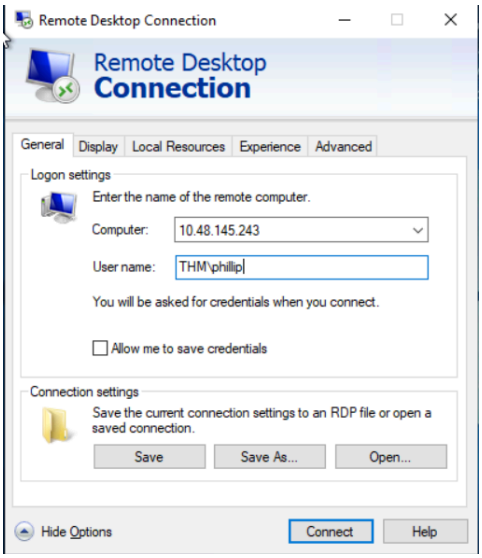
Result: Phillip can reset passwords only for users inside the Sales OU without having full administrative privileges.







Logging in as Delegated User via RDP



When logging in through Remote Desktop, specify the domain username using:

THM\phillip

Credentials:
Username: phillip
Password: Claire2008

Resetting User Password Using PowerShell

Phillip does not have permission to open ADUC, so password resets must be performed using PowerShell.

Reset Sophie's password:

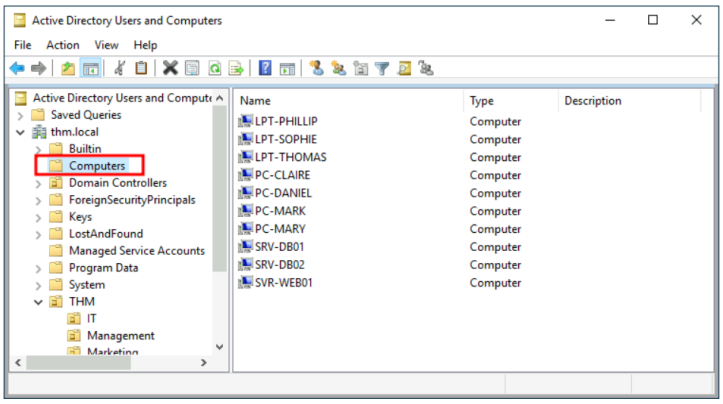
Set-ADAccountPassword sophie -Reset -NewPassword (ConvertTo-SecureString "NewPassword123!" -AsPlainText -Force)

Managing Computers in AD

Default Behaviour in Active Directory

When a machine joins a domain:

- It is automatically placed in the Computers container
- Exception: Domain Controllers (they go into a separate OU automatically)
- The Computers container is NOT an OU
- You cannot properly apply structured GPO strategies from it
- All devices are mixed together (bad practice)



If all devices stay inside the Computers container:

- Servers and user PCs are mixed
- Same policies may apply to all devices
- Security boundaries are weak
- Hard to manage large environments

➡ Different device types require different security baselines

Standard Device Segmentation in AD

Workstations

- End-user machines
- Desktops and laptops

- Used for:
  - Daily work
  - Web browsing
  - Office tasks

Privileged accounts (Domain Admins) should NOT log in here. Because Workstations are more exposed to malware and phishing

If compromised → admin credentials may be stolen

Servers
Machines that provide services

- File server
- Web server
- Application server
- Database server

Security Rule:
- Only administrators should log in
- Stricter firewall & monitoring policies

Servers require:
- Tighter control
- Stronger auditing
- Different GPOs than workstations

Domain Controllers
Machines managing the domain

Responsibilities:
- Authenticate users
- Store password hashes
- Apply Group Policies
- Maintain AD database
- Most sensitive systems in network.

- Already placed in Domain Controllers OU
- Do NOT manually move them unless instructed

Active Directory Group Policy (GPO)

Why We Created OUs
OUs are not just for organisation.

Main purpose:
Apply different Group Policies (GPOs) to different users and computers.

Example:
- Sales users → restricted settings
- Servers → stricter security
- IT users → more privileges

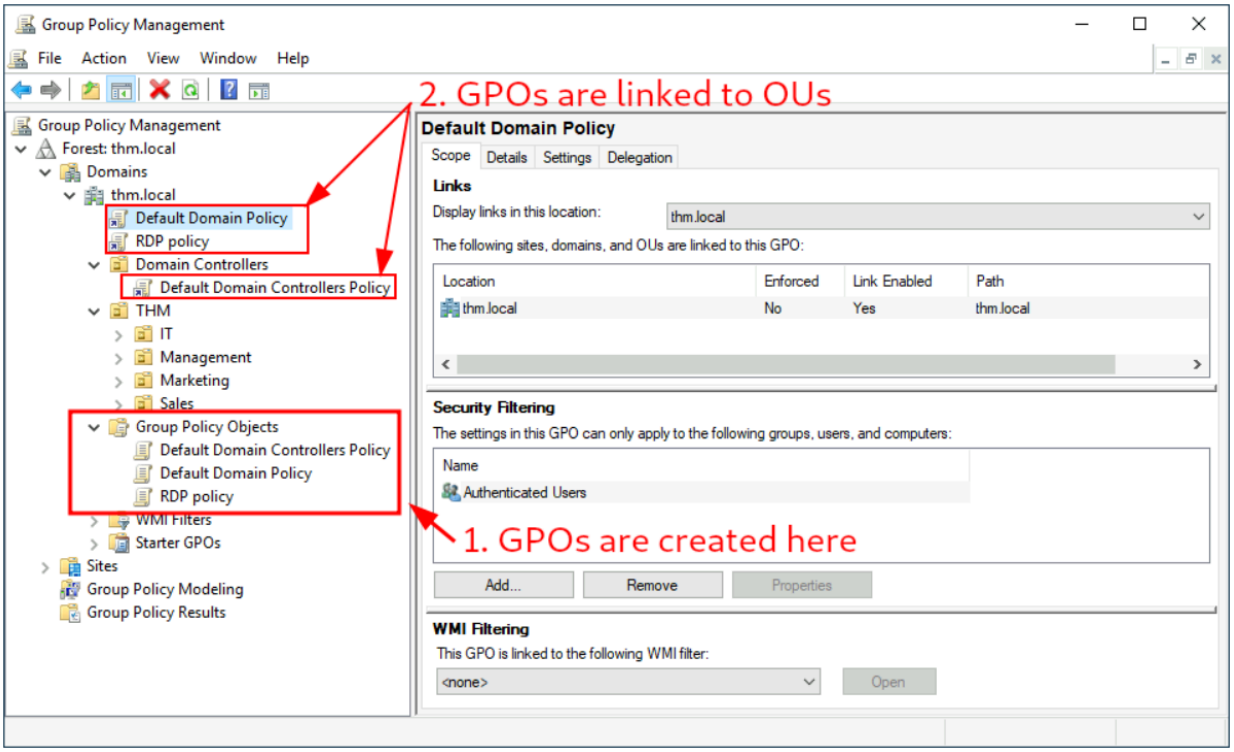
What is a GPO?

Group Policy Object (GPO) = Collection of configuration settings.

GPOs can apply to:

- Computer Configuration → affects machines
- User Configuration → affects user accounts

1. GPOs are created under Group Policy Objects
2. Then they are linked to an OU or domain
3. They apply to that OU + all child OUs



Managing GPOs

Tool used:

Group Policy Management

Steps:

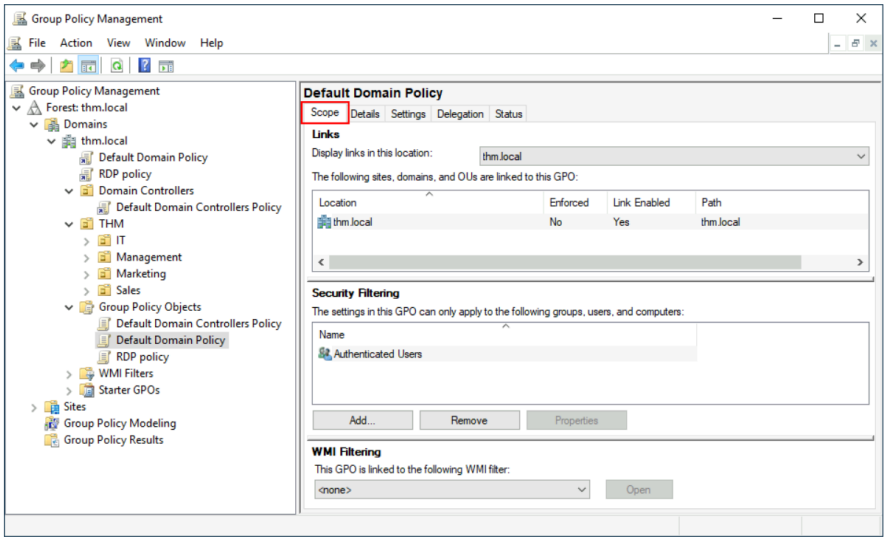
1. Open Start
2. Search Group Policy Management
3. View OU hierarchy

Default GPOs in Domain

Common default GPOs:

1. Default Domain Policy
   - Linked to: thm.local (root domain)
   - Affects: Entire domain
   - Contains:
     - Password Policy
     - Account Lockout Policy

2. Default Domain Controllers Policy
   - Linked to: Domain Controllers OU
   - Affects only DCs



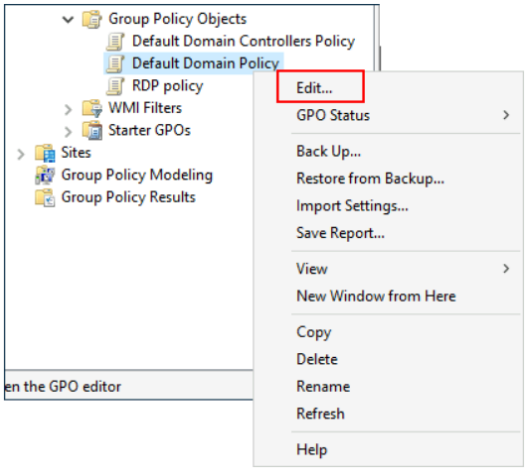
GPO Scope & Inheritance

GPO applies to linked OU + all sub-OUs

Example:
- If linked to thm.local → applies everywhere
- Sales OU still affected by Default Domain Policy

Editing a GPO

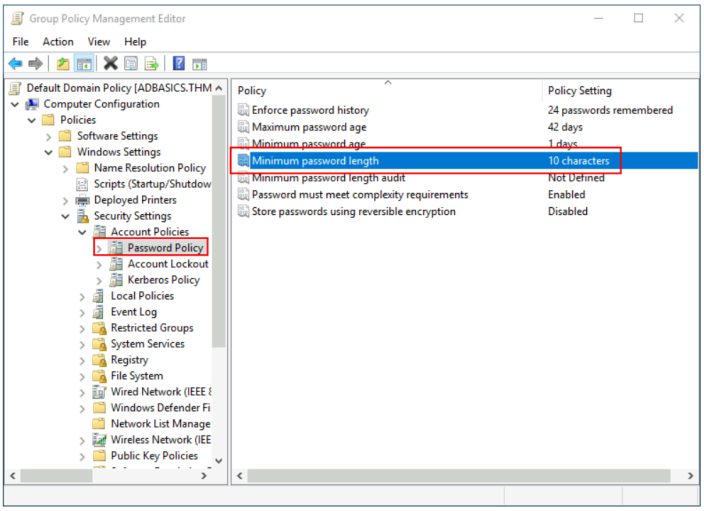
Steps:
1. Right-click GPO
2. Click Edit



Navigate through:
- Computer Configuration
- User Configuration

Example task: Change Minimum Password Length

Path:
1. Computer Configuration
2. → Policies
3. → Windows Settings
4. → Security Settings
5. → Account Policies
6. → Password Policy
7. → Minimum password length



Set to:
10 characters

Since the Default Domain Policy is linked to domain, it affects ALL users.

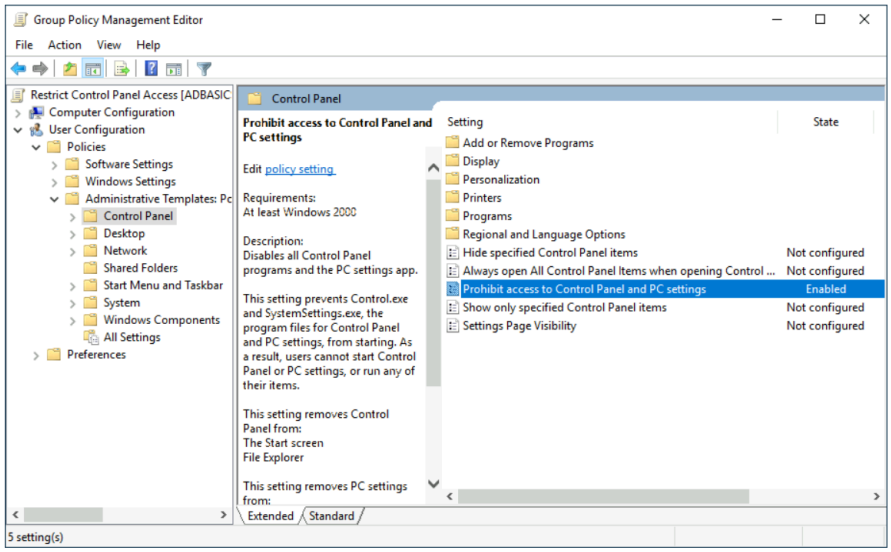
GPO Distribution

GPOs are stored in:
C:\Windows\SYSVOL\sysvol\

All domain users/computers:

- Periodically sync GPOs
- Refresh cycle ≈ 90 minutes (up to 2 hours)

Force update manually:
gpupdate /force



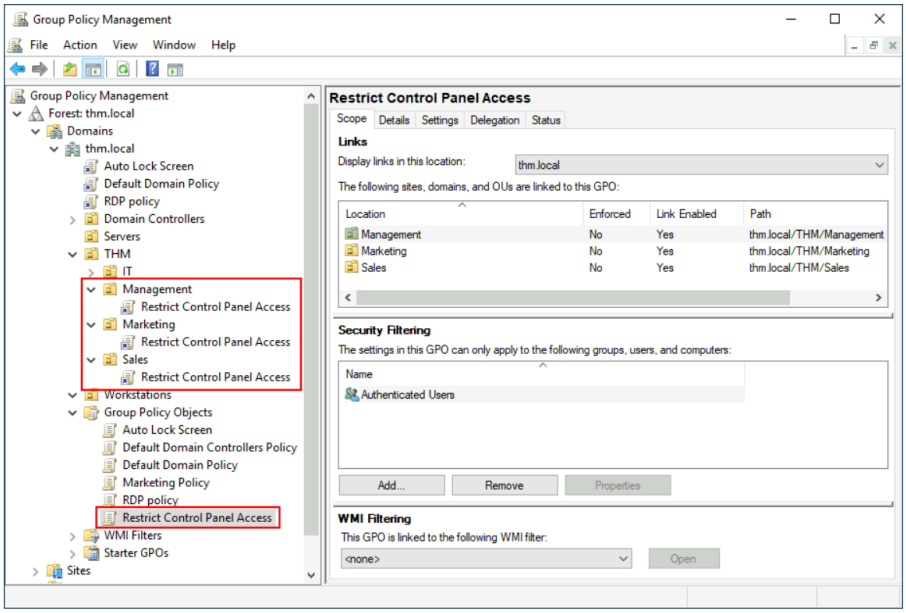
THM Practical GPO Tasks

We must implement:

1. Restrict Control Panel access (non-IT use
2. Auto lock screen after 5 minutes inactivity

1.
Notice we have enabled the Prohibit Access to the Control Panel and PC settings policy.

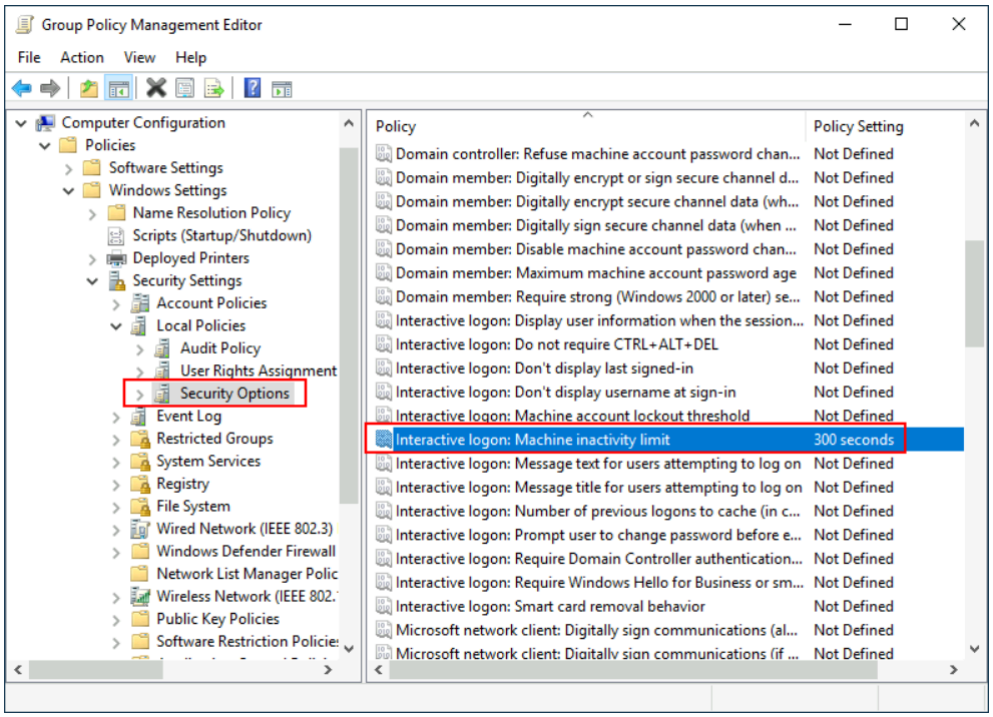
Once the GPO is configured, we will need to link it to all of the OUs corresponding to users who shouldn't have access to the Control Panel of their PCs. In this case, we will link the Marketing, Management and Sales OUs by dragging the GPO to each of them:



2.

Let's create a new GPO, call it Auto Lock Screen, and edit it. The policy to achieve what we want is located in the following route:

We will set the inactivity limit to 5 minutes so that computers get locked automatically if any user leaves their session open.
After closing the GPO editor, we will link the GPO to the root domain by dragging the GPO to it.



Windows Domain Authentication

In a Windows domain:

- All credentials are stored on Domain Controllers
- Authentication requests are verified by the DC

Two authentication protocols:

1. **Kerberos** → Default (modern Windows domains)
2. **NetNTLM** → Legacy (kept for compatibility)

Most real environments still have both enabled.

Kerberos Overview

Kerberos = Ticket-based authentication protocol

➡ User authenticates once
➡ Receives tickets
➡ Uses tickets to access services
➡ Does NOT resend password repeatedly

Main component:

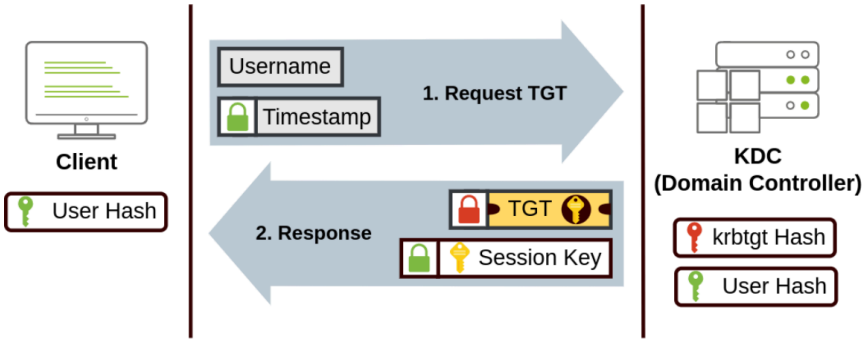
Key Distribution Center (KDC)

- Runs on the Domain Controller
- Issues Kerberos tickets

Important Kerberos Terms

- KDC → Key Distribution Center (Ticket issuer)
- TGT → Ticket Granting Ticket
- TGS → Ticket Granting Service ticket
- SPN → Service Principal Name
- Session Key → Temporary symmetric key
- krbtgt → Special AD account used to encrypt TGTs

Kerberos Authentication Flow



Step 1 — Initial Authentication (Get TGT)

The user logs in.

1. User sends to KDC:

- Username
- Timestamp
  - Encrypted using key derived from user password

2. KDC verifies credentials. If valid, KDC sends:

- TGT (Ticket Granting Ticket)
- Session Key

Important details:

- TGT is encrypted with krbtgt account hash
- User cannot read TGT contents
- TGT contains:
  - User info
  - Copy of Session Key
- KDC does NOT store Session Key
  - It can recover it by decrypting TGT

Purpose of TGT:

- Allows user to request service tickets
- Avoids sending password again

Step 2 — Requesting a Service Ticket (TGS)

User wants to access a service:

- File share
- Website
- Database

1. User sends to KDC:

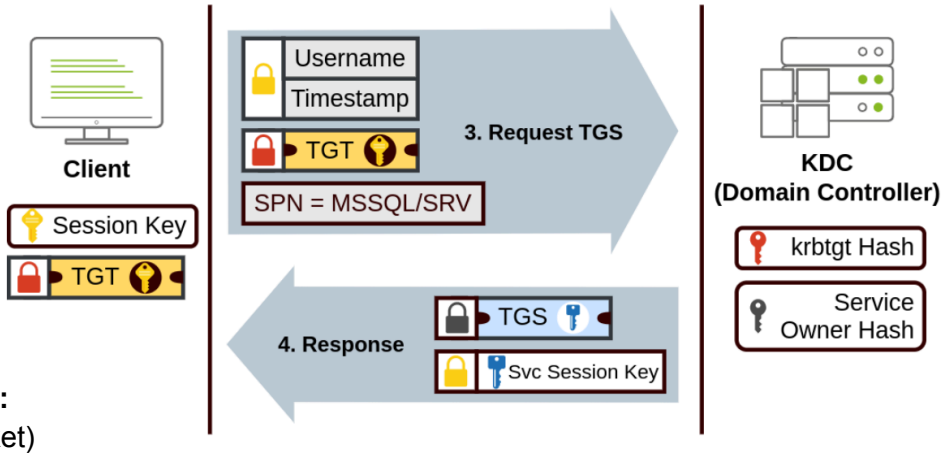
- Username
- Timestamp encrypted with Session Key
- TGT
- SPN (Service Principal Name)

SPN identifies:

- Service type
- Server hosting service

Example:

- HTTP/webserver.thm.local



2. KDC verifies TGT. If valid, KDC sends:

- TGS (Ticket Granting Service ticket)
- Service Session Key

Important:

- TGS is encrypted with Service Owner's password hash
- Service Owner = user or machine account running the service
- TGS contains:
  - Service Session Key (inside encrypted portion)

Step 3 — Accessing the Service

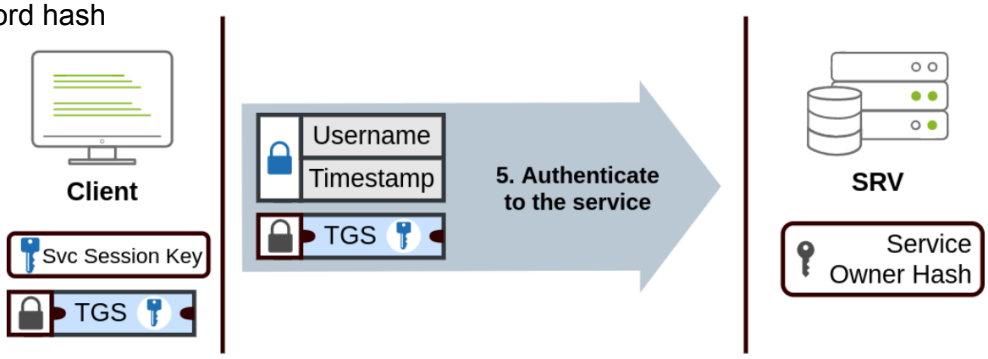
1. User sends:

- TGS
- Authenticator (timestamp encrypted with Service Session Key)

2. Service:

- Decrypts TGS using its password hash
- Extracts Service Session Key
- Verifies authenticator
- Grants access

Connection established.



NetNTLM Authentication

NetNTLM (NTLM over network) is a:

- Legacy Windows authentication protocol
- Based on challenge–response
- Still enabled in many networks for compatibility

Used when:

- Kerberos is not available
- Authentication is done via IP instead of hostname
- Accessing older systems
- Cross-domain situations without trust

NetNTLM Authentication Flow

Step 1 — Authentication Request

Client → Server

User attempts to access:

- File share
- Web service
- Remote system

1. Client sends:

- Username
- Authentication request

Step 2 — Server Sends Challenge

Server generates:

- Random number (nonce)

1. Server → Client:

- Sends challenge
- This challenge ensures:
    - Fresh authentication
    - Protection against replay attacks

Step 3 — Client Generates Response

Client:

- Takes NTLM password hash
- Combines it with:
  - Challenge
  - Other protocol data
- Generates cryptographic response

1. Client → Server:

- Sends response

Step 4 — Server Forwards to Domain Controller

The server does NOT verify the password itself.

1. Server → Domain Controller:

- Sends:
  - Challenge
  - Client response
  - Username

Step 5 — Domain Controller Verification

1. Domain Controller:

- Retrieves user's NTLM hash from database
- Uses same challenge
- Recalculates expected response
- Compares with client response

If match:

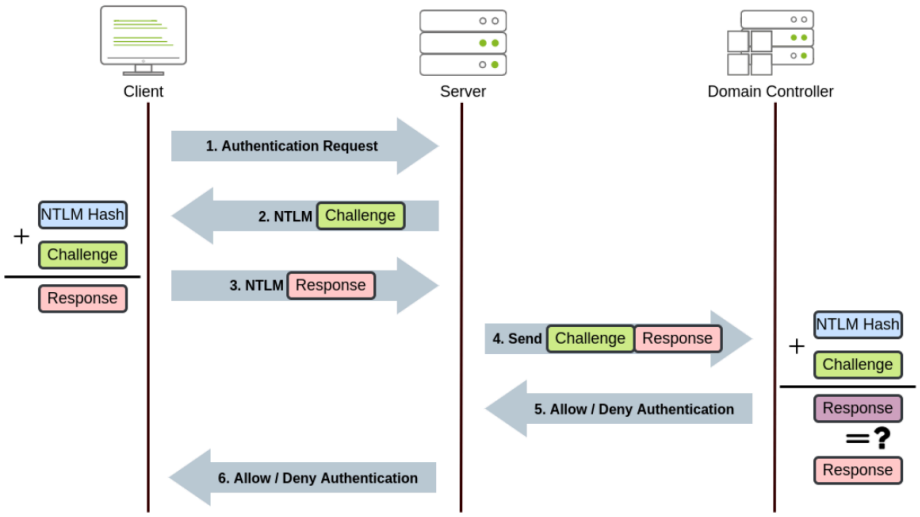
- Authentication successful

If mismatch:

- Authentication denied

Step 6 — Result Returned

Domain Controller → Server
Server → Client
Authentication result delivered.



Trees, Forests & Trusts

Triggers for multiple domains:

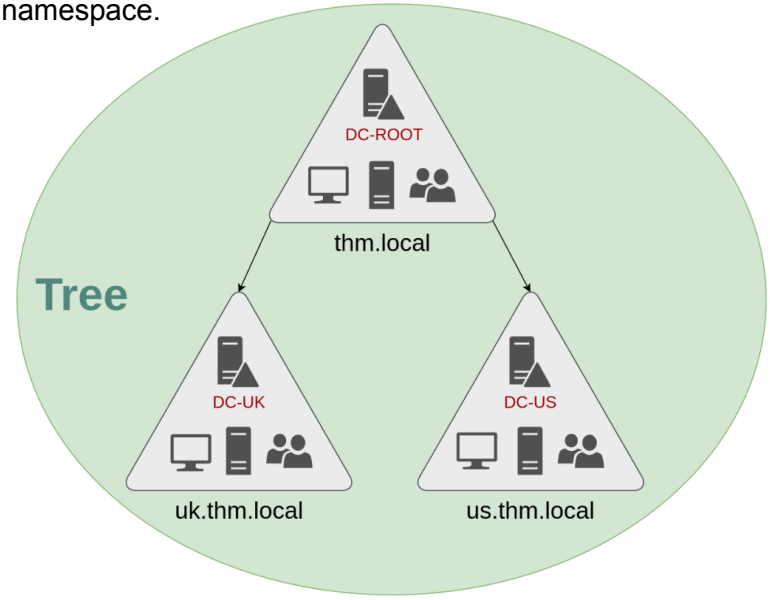
- Expansion to other countries
- Different legal requirements
- Separate IT teams
- Independent security policies
- Reduced administrative interference

Instead of:

- Overcomplicated OU structure
- Excessive delegation

Trees in Active Directory

A Tree = Multiple domains sharing the same namespace.



- Root domain:
  - thm.local
-
- Subdomains:
  - Uk.thm.local
  - Us.thm.local

Characteristics of a Tree

Same namespace hierarchy

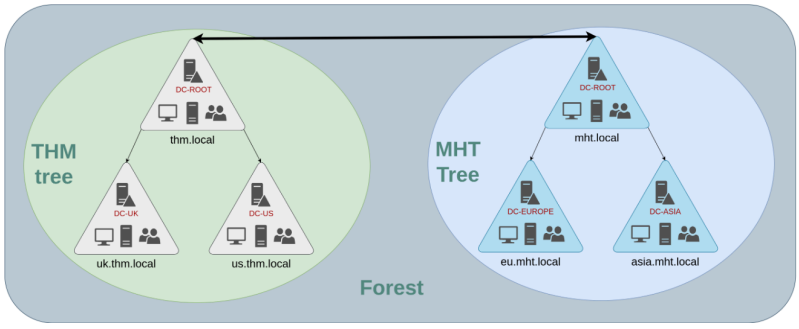
- Each domain has:
  - Its own Domain Controller
  - Its own users & computers
  - Its own policies
- Administrative separation
  - Example:
    - UK IT admins manage uk.thm.local
    - US IT admins manage us.thm.local
    - UK admins cannot manage US domain

Forests in Active Directory

A Forest = Collection of multiple domain trees with different namespaces.

Used when:

- Company merger
- Acquisition



- Independent domain structures need coexistence
- Separate IT governance

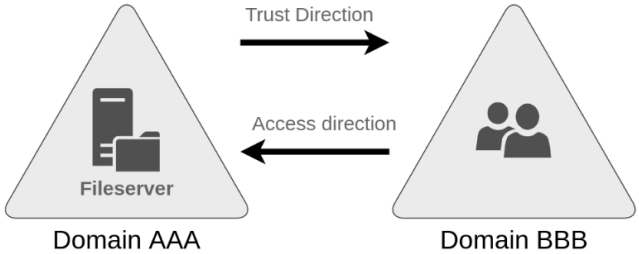
Each tree:
- Maintains autonomy
- Shares enterprise-level trust

Trust Relationships

Trust = Mechanism allowing authentication between domains.

Without trust:
Users from Domain A cannot access Domain B resources

With trust:
Cross-domain authentication possible



One-Way Trust

If Domain AAA trusts Domain BBB:
- Users from BBB can access resources in AAA
- AAA accepts authentication from BBB

Two-Way Trust

- Both domains trust each other
- Users from both domains can be authorised cross-domain
- By default:
    - Domains inside same tree or forest → Two-way trust